[/]

DOJOCONF/

A case for Event Driven Cloud Detection and Response

01/08/2026 · Santiago Abastante

Slides



/intro

Santi Abastante

About Me
- Former Police Officer
- Cloud Security Engineer
- Incident Responder
- Digital Nomad

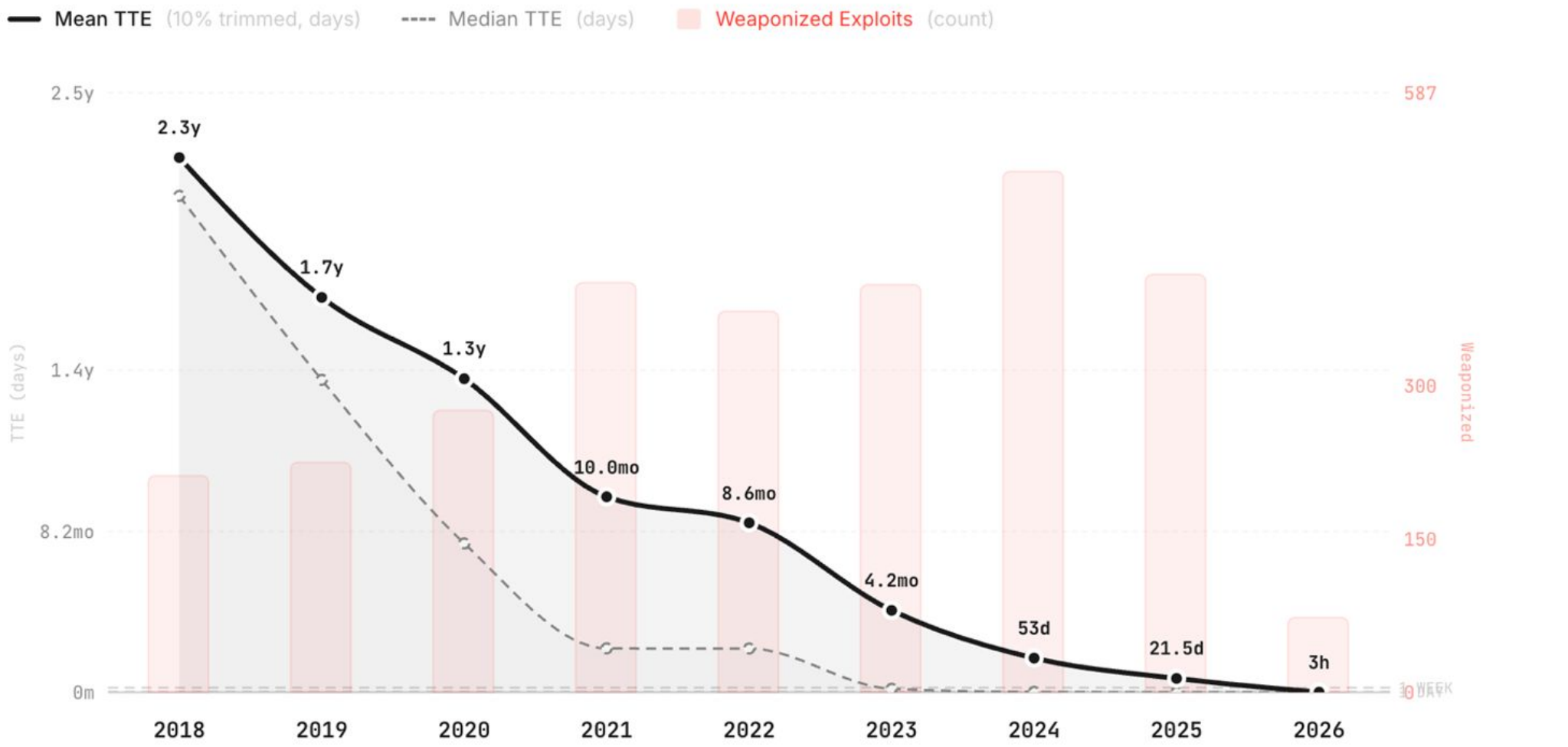


[02]

Context

From Vulnerability to Exploitation

TTE measures the gap between CVE public disclosure and first confirmed in-the-wild exploitation. Zero = same-day.

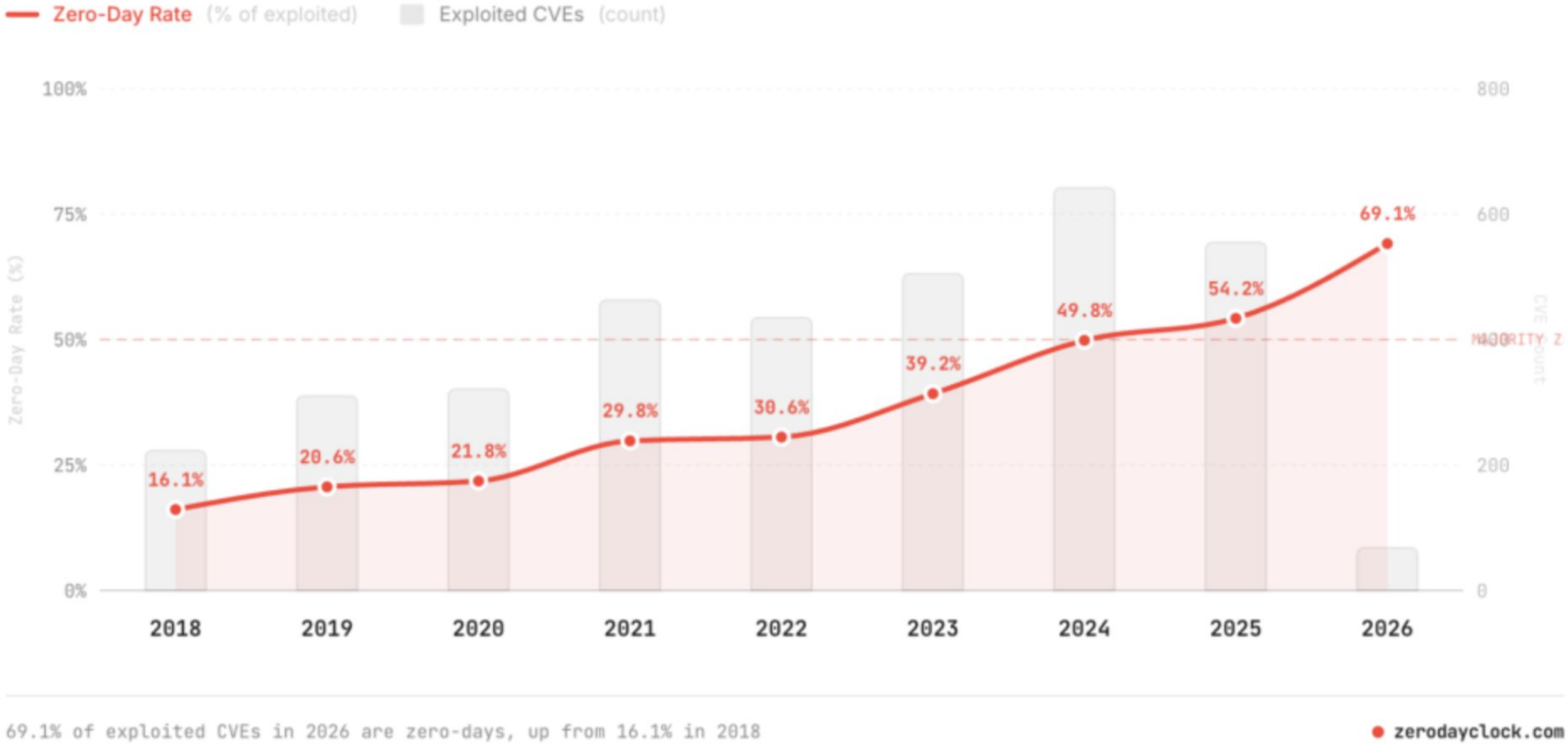


Based on 3,500+ confirmed-exploited CVEs (CISA KEV + VulnCheck KEV, with VulnCheck XDB timestamps for early-year CVEs)

zerodayclock.com

Zero-Day Rate

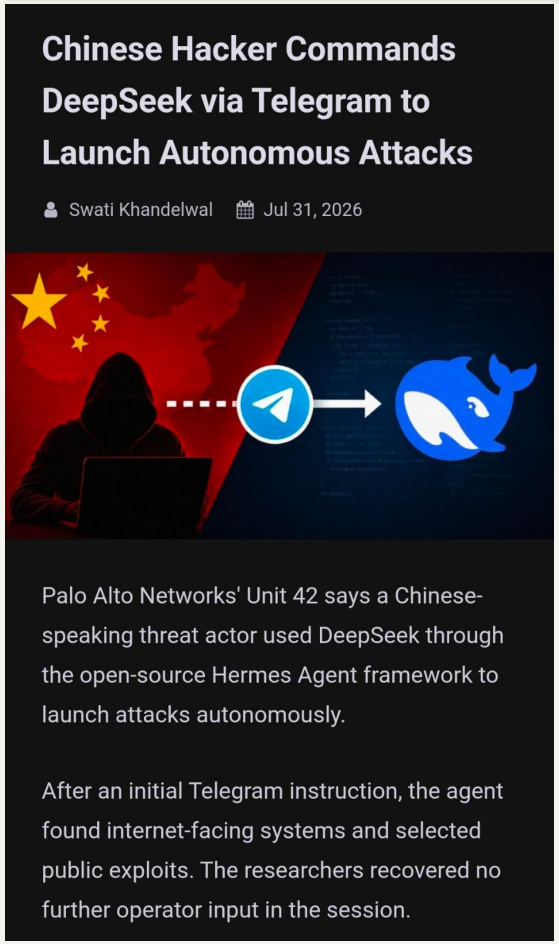
Percentage of exploited CVEs where exploitation occurred before or on the day of disclosure (TTE ≤ 0)



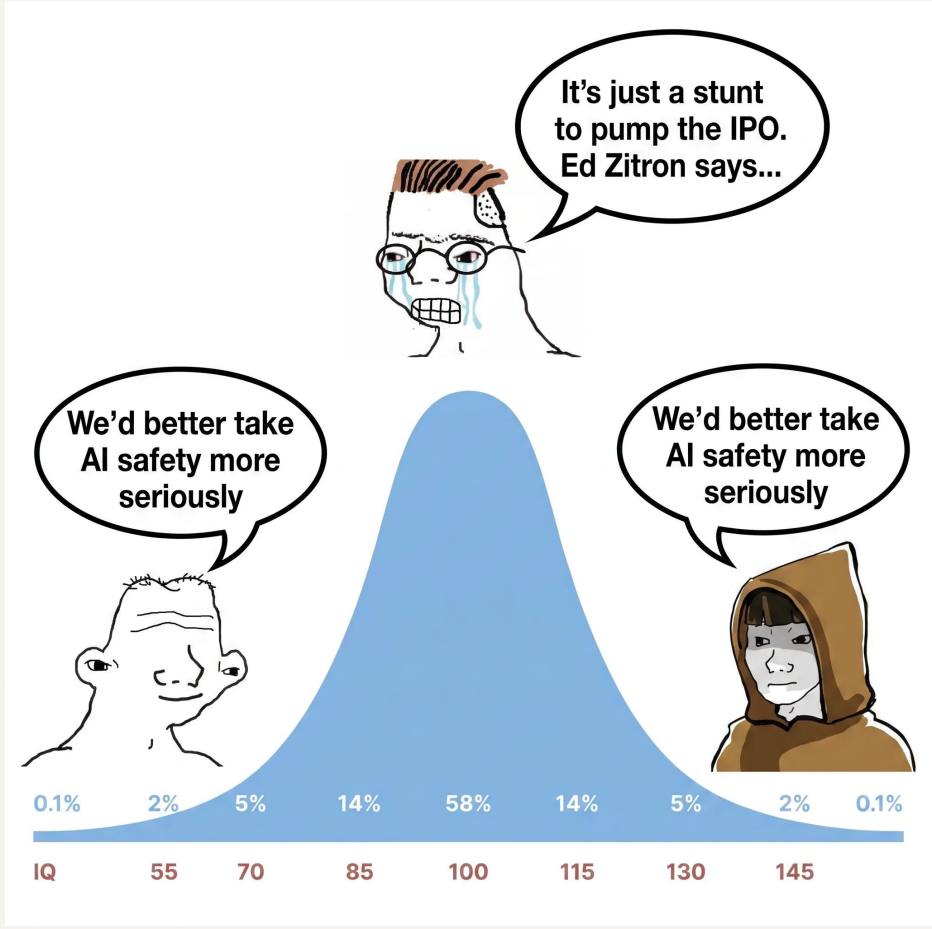
69.1% of exploited CVEs in 2026 are zero-days, up from 16.1% in 2018

zerodayclock.com

This is the world today







One does not simply patches everything

- Assume **Zero-Day Discovery** Is Commodity.
- Reduce Blast Radius.
- **Detect Exploitation**, Not Just Vulnerabilities.
- **Automate Response**.
- Raise Human Awareness!



> **”All we have to decide is what to do with the time that is given us.”**
>
> *Gandalf - Lord of The Rings*

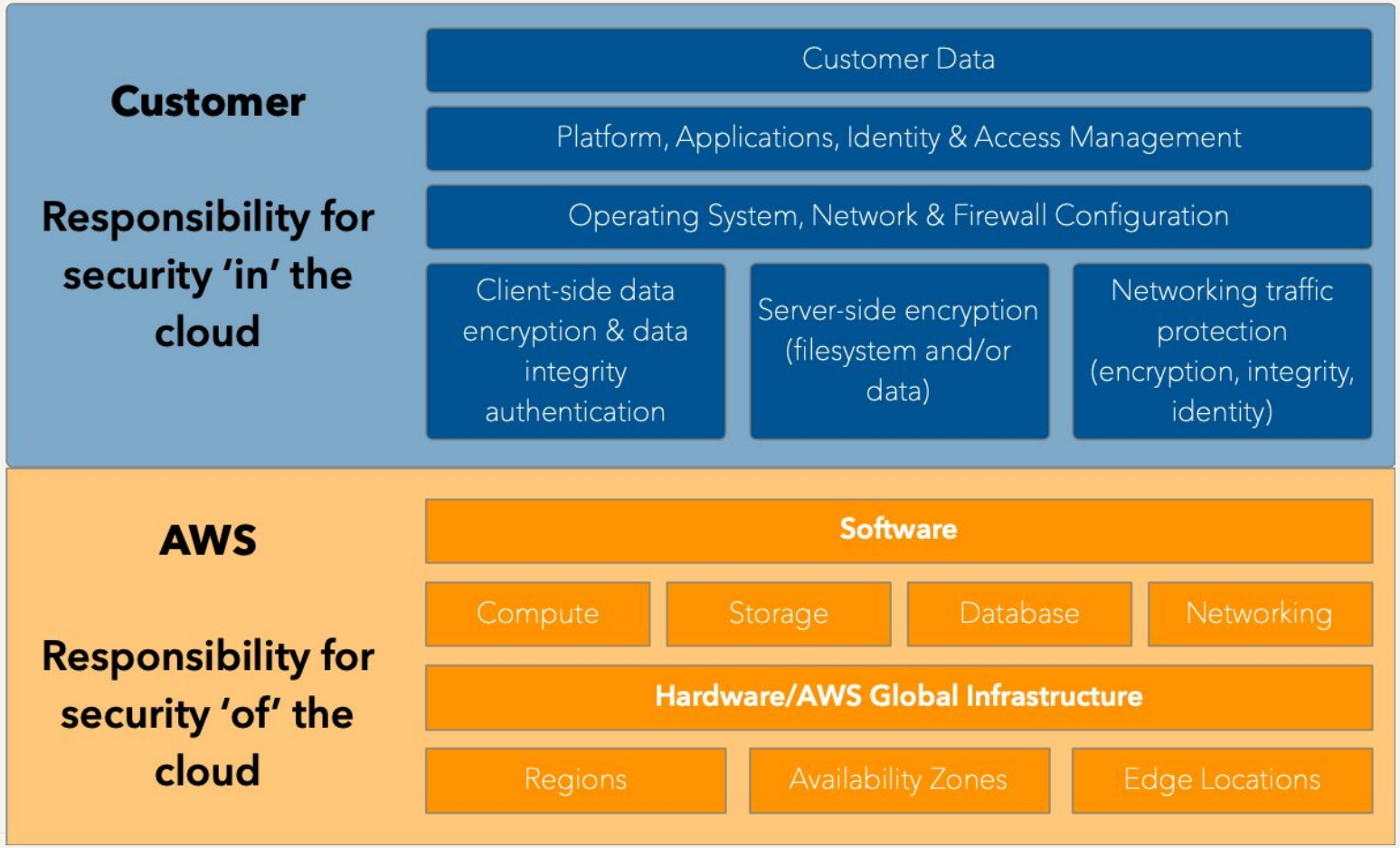
— dbnz/

[02]

AWS Logging and Monitoring

The Share Responsibility Model

- Establishes **who owns what**, the Cloud Provider or the Cloud User,
- Security can not be delegated,
- It also means **we struggle to add visibility controls**,
- Attackers can take advantage of the lack of visibility to execute attacks.
- Example: Lambda Functions and EDR

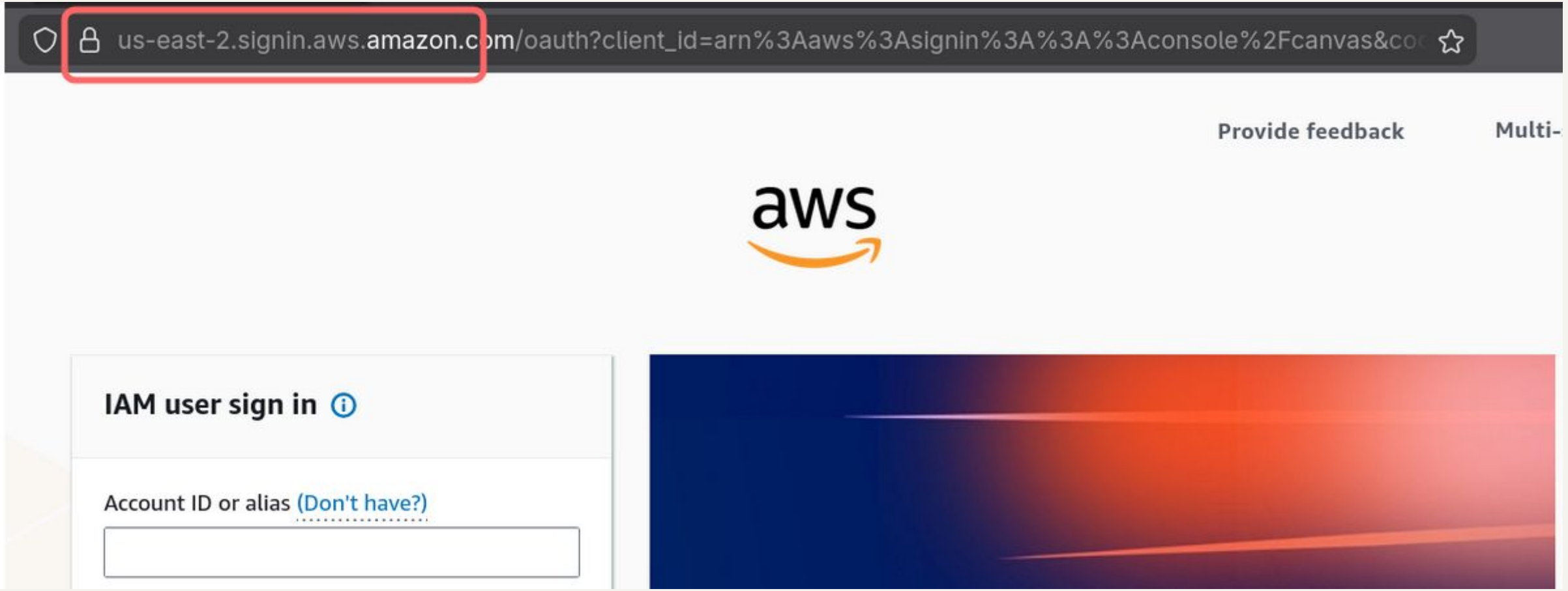


Cloud Segmentation

- Cloud Providers distribute their infrastructure in different parts of the world,
- Most AWS Services are Regional,
- Some of them are Global,
- **Security Services must be enabled in every active Region**.
- Attackers can exploit Global endpoints to evade defenses.



Cloud Segmentation - Regional Services



> ”Every Service in AWS is an API, and every API Call executed is logged in Cloudtrail”

— dbnz/

Cloudtrail

- **Every Service in AWS is an API,**
- **Cloudtrail Logs every API Call,**
- Can be consumed in 3 ways, each one with different delays and tradeoffs,
- Can be consumed using S3, Cloudwatch or Event Bridge,
- Most important Forensic Artifact for IR,
- **Most integrations require the creation of additional infrastructure,**
- **Some API Call require additional configurations.**



Cloudtrail Log examples



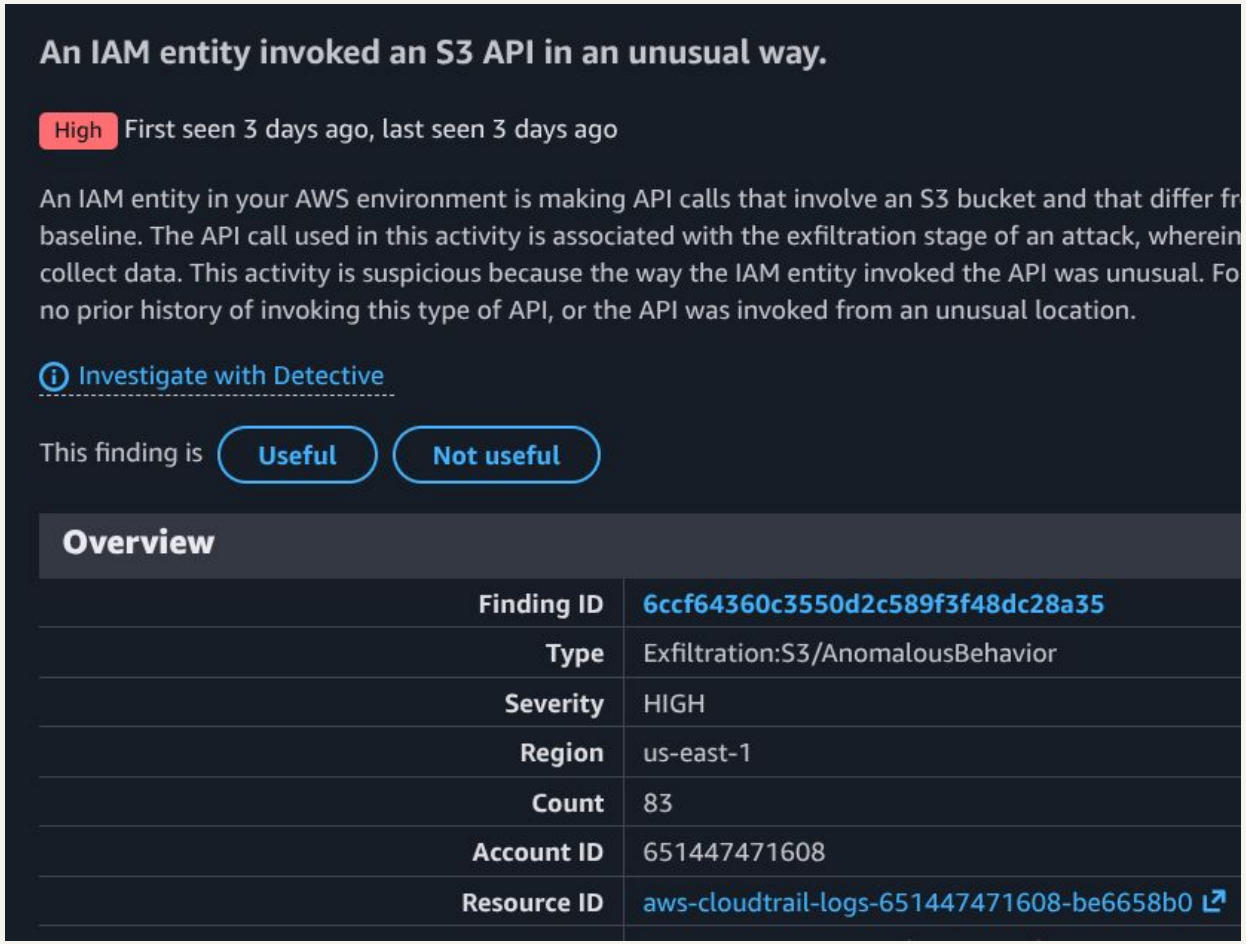


Guardduty

- AWS Threat Detection and Response,
- **Correlates events from API Logs, Network Logs, DNS, Logs, etc,**
- Cannot create custom rules,
- Uses IA for detection;
- **Delays: Up to 15 Min,**
- It's getting better every year.



Guardduty finding Example



An IAM entity invoked an S3 API in an unusual way.

High First seen 3 days ago, last seen 3 days ago

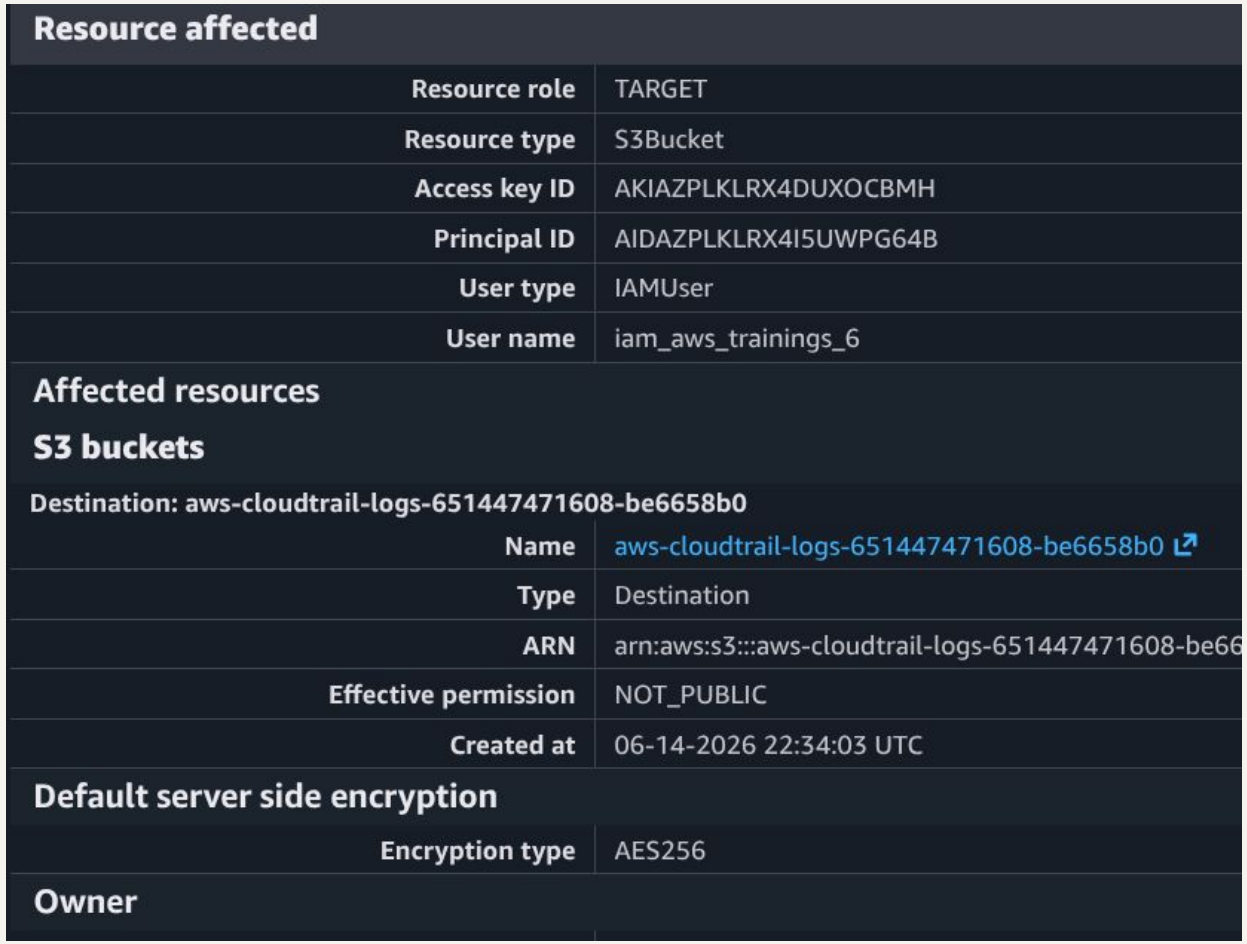
An IAM entity in your AWS environment is making API calls that involve an S3 bucket and that differ fr
baseline. The API call used in this activity is associated with the exfiltration stage of an attack, wherein
collect data. This activity is suspicious because the way the IAM entity invoked the API was unusual. Fo
no prior history of invoking this type of API, or the API was invoked from an unusual location.

Investigate with Detective

This finding is Useful Not useful

Overview

Finding ID	6ccf64360c3550d2c589f3f48dc28a35
Type	Exfiltration:S3/AnomalousBehavior
Severity	HIGH
Region	us-east-1
Count	83
Account ID	651447471608
Resource ID	aws-cloudtrail-logs-651447471608-be6658b0



Resource affected

Resource role	TARGET
Resource type	S3Bucket
Access key ID	AKIAZPLKLRX4DUXOCBMH
Principal ID	AIDAZPLKLRX4I5UWPG64B
User type	IAMUser
User name	iam_aws_trainings_6

Affected resources

S3 buckets

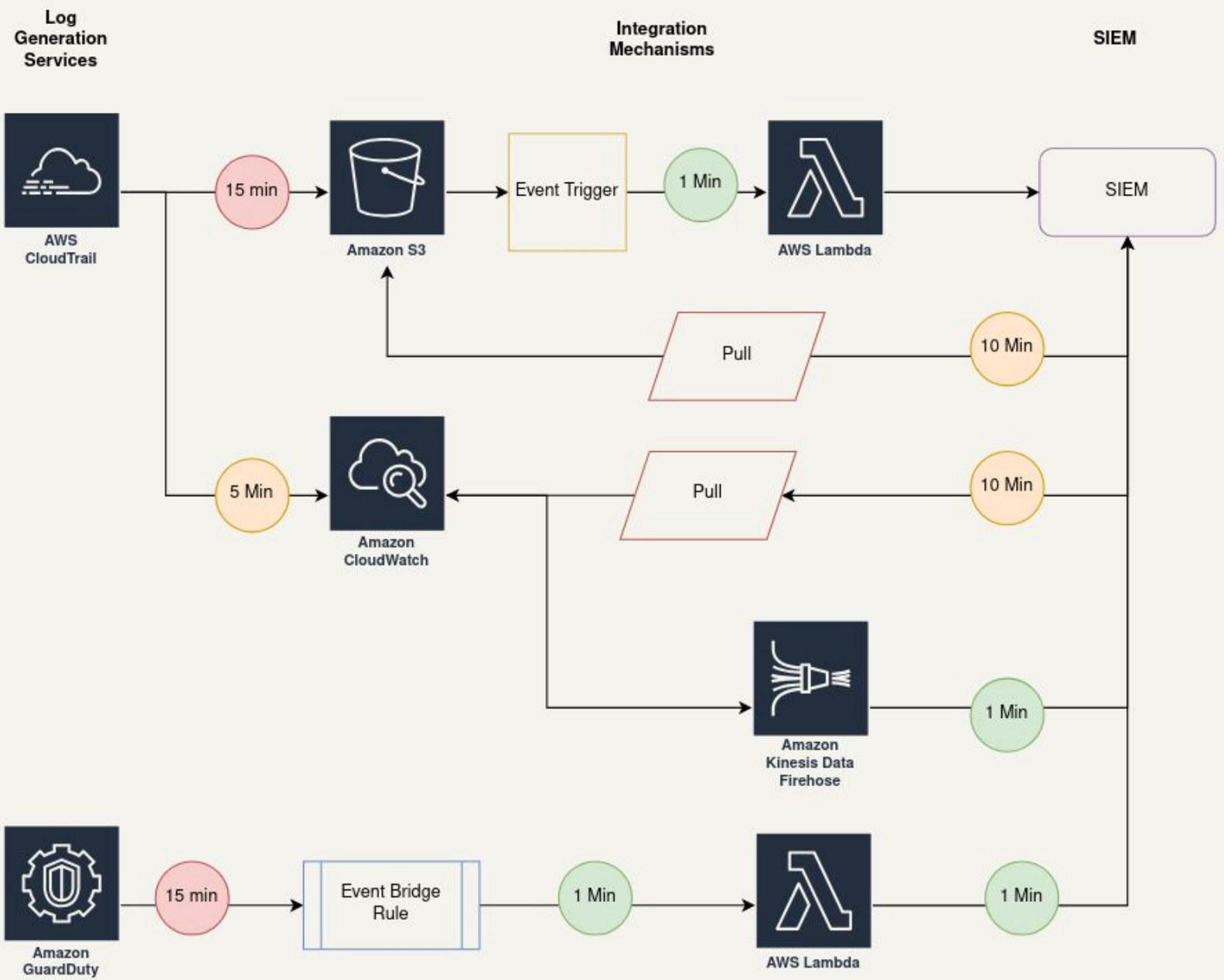
Destination: aws-cloudtrail-logs-651447471608-be6658b0

Name	aws-cloudtrail-logs-651447471608-be6658b0
Type	Destination
ARN	arn:aws:s3:::aws-cloudtrail-logs-651447471608-be66
Effective permission	NOT_PUBLIC
Created at	06-14-2026 22:34:03 UTC

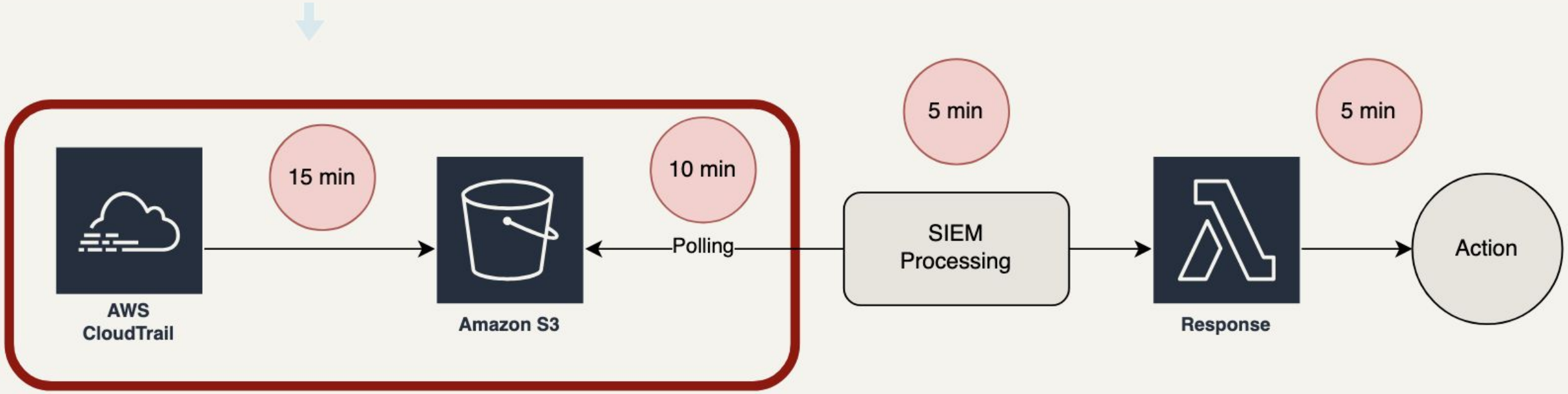
Default server side encryption

Encryption type	AES256

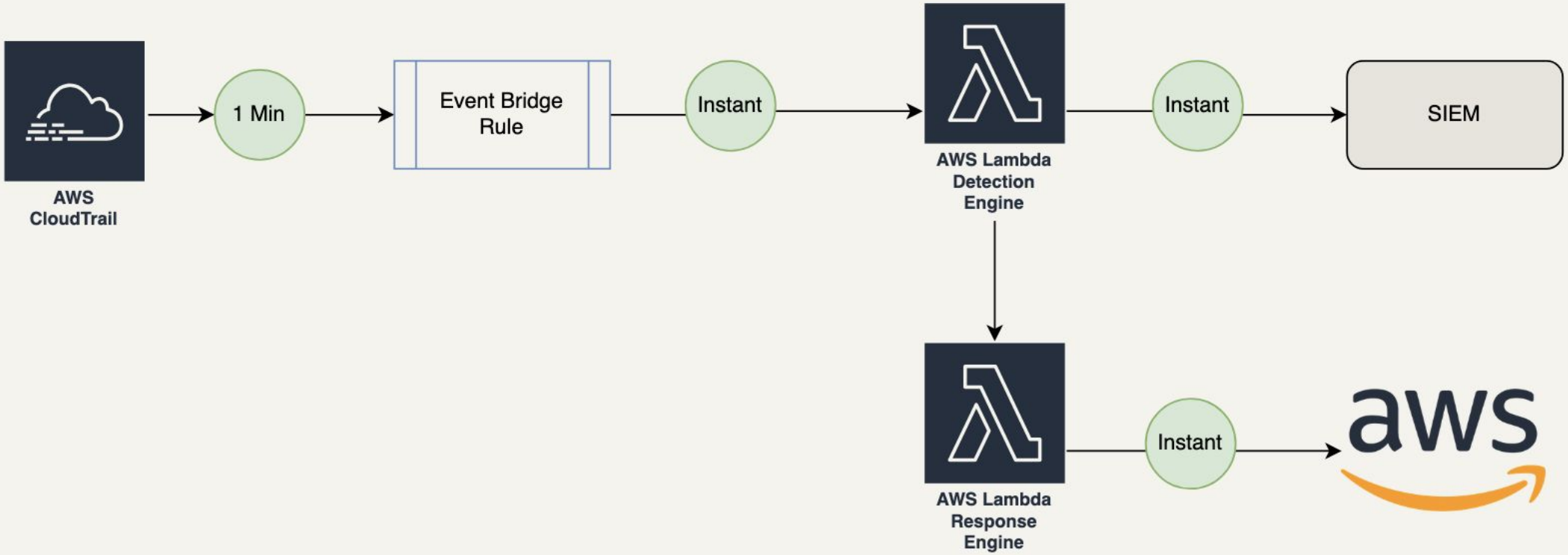
Owner


Log Generation Services
Integration Mechanisms
SIEM
AWS CloudTrail
15 min
Amazon S3
Event Trigger
1 Min
AWS Lambda
SIEM
Pull
10 Min
5 Min
Amazon CloudWatch
Pull
10 Min
Amazon Kinesis Data Firehose
1 Min
Amazon GuardDuty
15 min
Event Bridge Rule
1 Min
AWS Lambda
1 Min

Traditional SIEM Detection and Response Architecture



Proposed AWS Detection and Response Architecture



[03]

OpenCDR

Prior Work: Dredge and the Incident Response Perspective

README MPL-2.0 license

Dredge - 0.2.0

CI License MPL 2.0 coverage 86%

⚡ Log collection, analysis, and rapid response in the cloud... pa' la hinchada⚡

TL;DR

- Python library + CLI for cloud incident response and threat hunting.
- **AWS**: containment, forensics, and hunting across IAM, EC2, RDS, ECS, S3, Lambda, KMS, GuardDuty, Security Hub, CloudTrail, and more.
- **GitHub**: org/enterprise audit log hunting.
- **GCP**: Cloud Logging hunting (in progress).
- 299 tests, 86% coverage, 80% floor enforced in CI.

Dredge is designed for rapid cloud IR — especially when you don't have all the plumbing ready at 3AM. It exposes a clean, composable Python API you can import into your own tooling and a CLI for direct use from the terminal.

Current Features

Response (AWS) — Containment

Action	Method
Disable / delete IAM access key	`response.disable_access_key` / `delete_access_key`
Disable / delete IAM user	`response.disable_user` / `delete_user`
Disable IAM role (detach policies, clear trust)	`response.disable_role`
Delete MFA devices for a user	`response.delete_mfa_devices`
Revoke active IAM sessions (deny policy)	`response.revoke_active_sessions`
Detach a single managed policy from user/role	`response.detach_iam_policy`
Block S3 public access (account-level)	`response.block_s3_public_access`

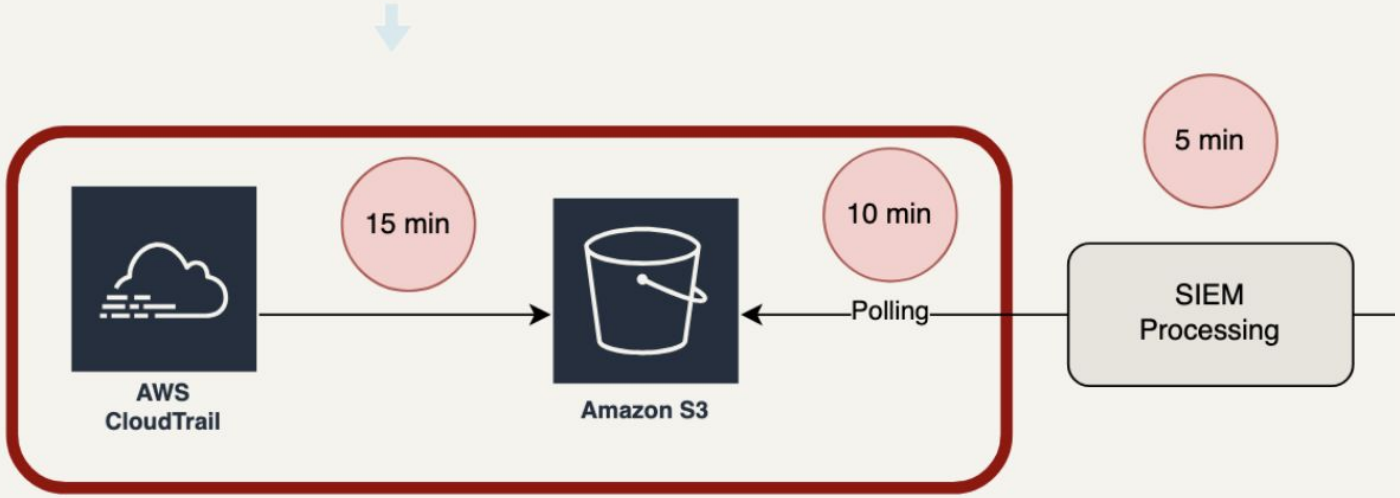
Forensics (AWS)

Action	Method
Snapshot EBS volume	`forensics.get_ebs_snapshot`
Snapshot all volumes on an EC2 instance	`forensics.snapshot_instance_volumes`
Capture Lambda environment variables	`forensics.get_lambda_environment`
Enable VPC flow logs (CloudWatch or S3)	`forensics.enable_vpc_flow_logs`
Retrieve completed SSM session history	`forensics.capture_ssm_session_history`
Check CloudTrail trail status and event selectors	`forensics.get_cloudtrail_status`

https://github.com/dbnz-io/dredge

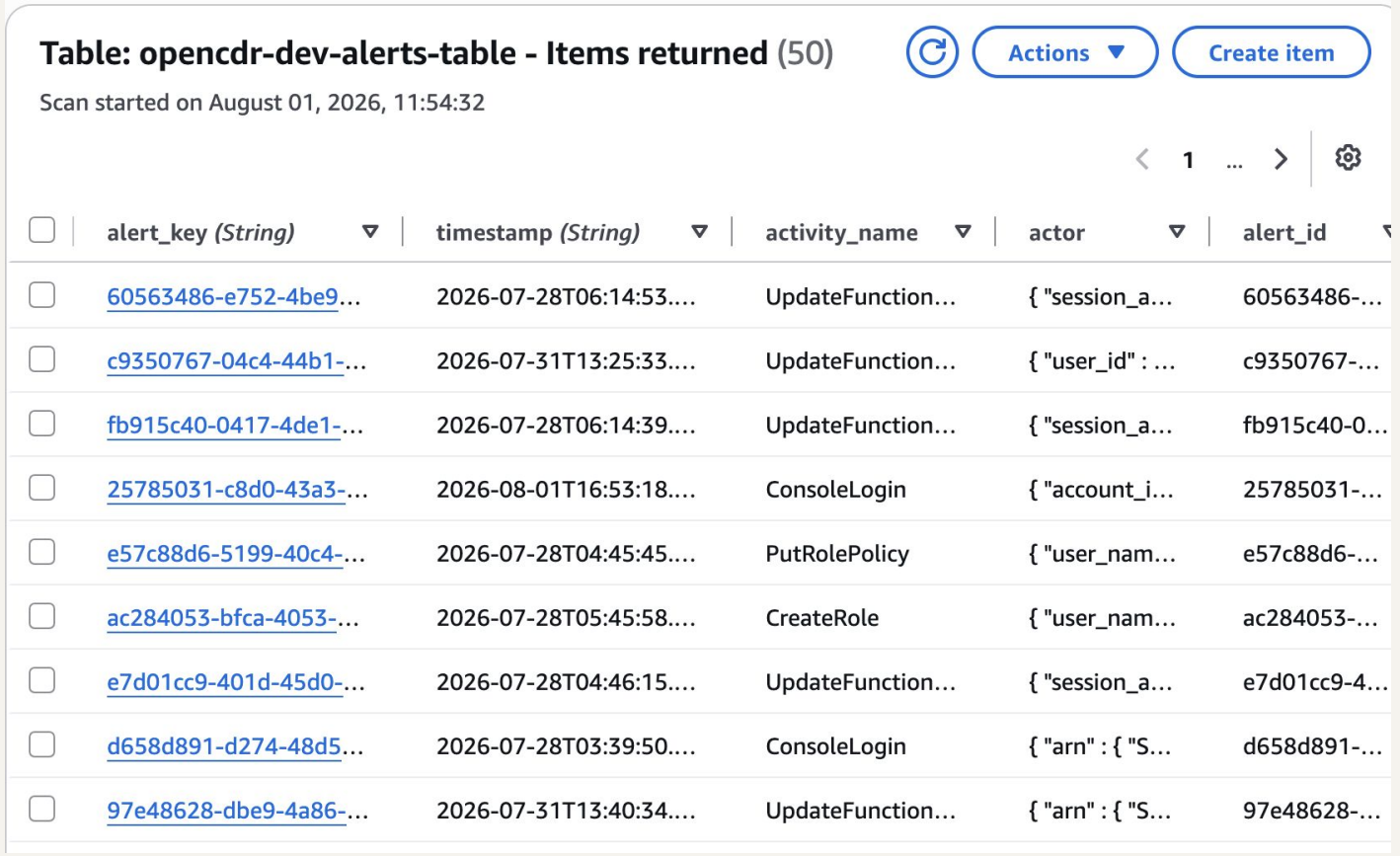
OpenCDR Principles: No polling

- **100% Event Driven**
- EventBridge delivers events to the processor Lambda.
- DynamoDB Streams deliver signal writes to the alerter Lambda.
- There is no component that wakes up on a timer and asks "is there anything new?".
- **This is the most important structural difference from conventional SIEM architectures.**
- Near real time.



OpenCDR Principles: Explicit detection state.

- Detection results—signals—are stored as first-class records in DynamoDB with a stable identity derived from the CloudTrail event ID.
- **Every detection is addressable, queryable, and auditable** independently of the detection rule that produced it.
- Correlation operates over stored signals, not over a stream of raw events that may or may not be available.
- **The state of the detection system at any point in time is fully inspectable.**



OpenCDR Principles: Idempotency at every write.

- Every write to DynamoDB uses a conditional expression that prevents duplicate records.
- The outbox pattern ensures that alert delivery to SQS cannot be lost without being recorded in the outbox table.
- **This makes the pipeline safe to retry at any stage without producing false alerts.**

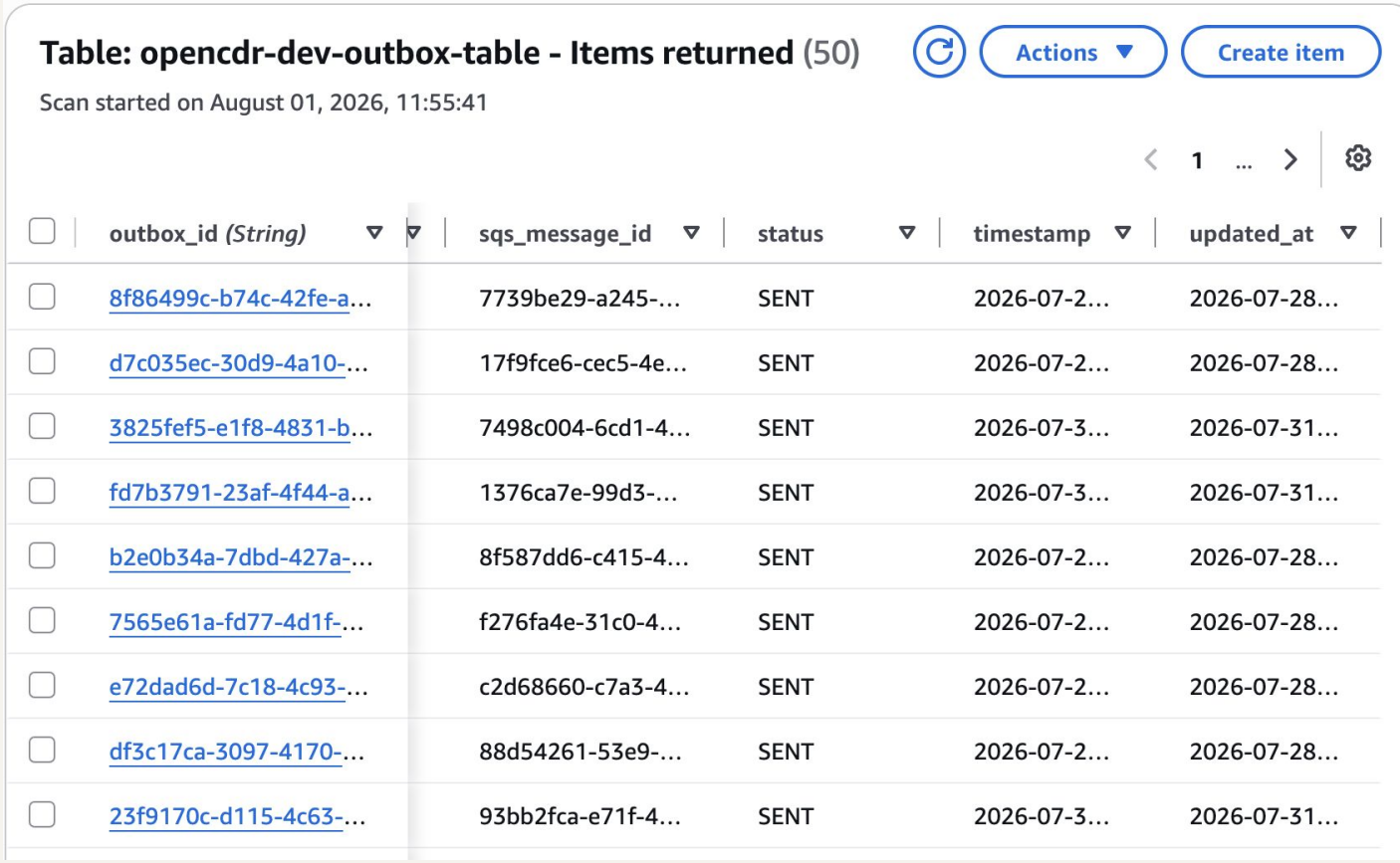


Table: opencdr-dev-outbox-table - Items returned (50)

Actions | Create item

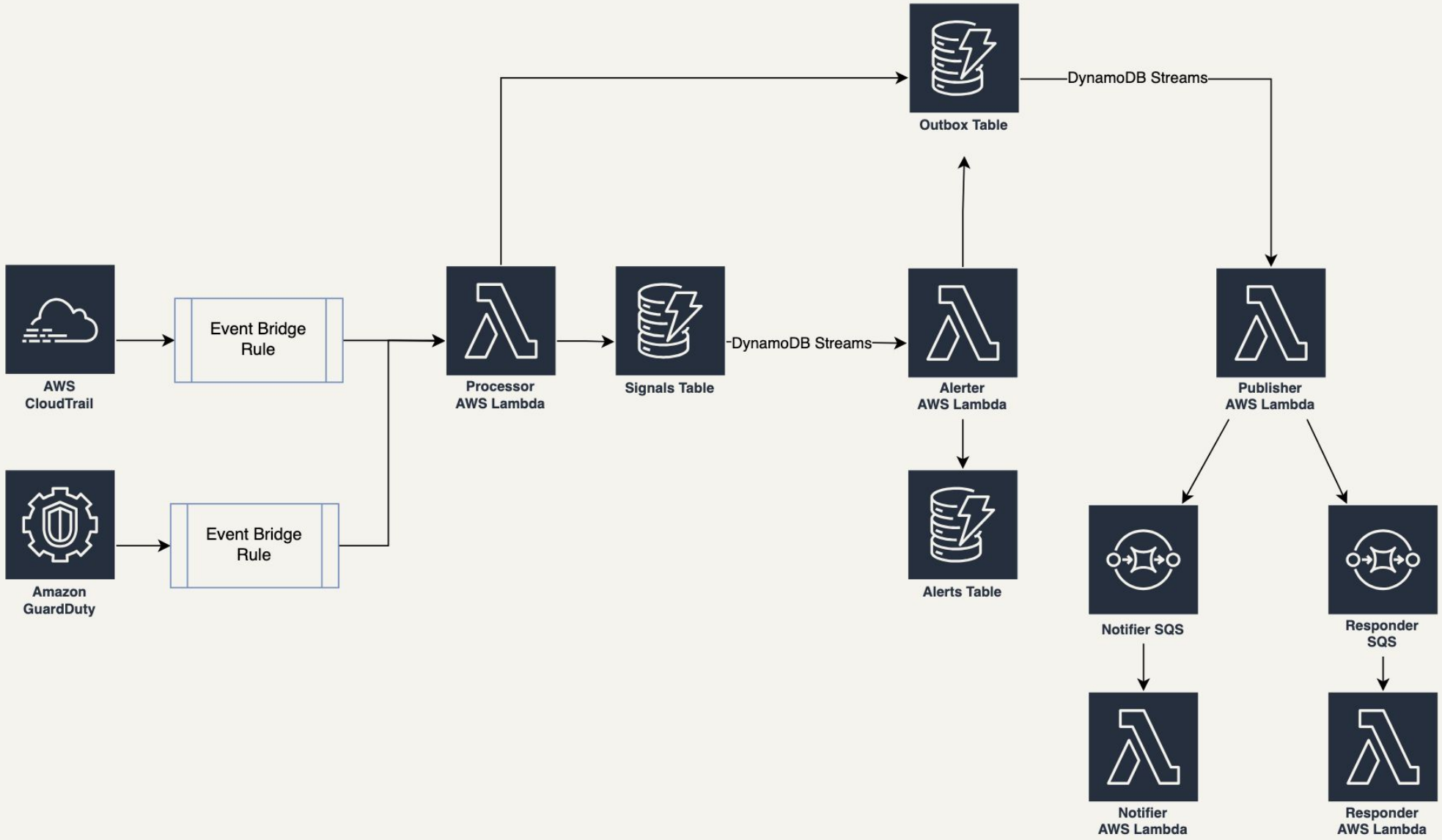
Scan started on August 01, 2026, 11:55:41

1 ...

outbox_id *(String)*	sqs_message_id	status	timestamp	updated_at
8f86499c-b74c-42fe-a...	7739be29-a245-...	SENT	2026-07-2...	2026-07-28...
d7c035ec-30d9-4a10-...	17f9fce6-cec5-4e...	SENT	2026-07-2...	2026-07-28...
3825fef5-e1f8-4831-b...	7498c004-6cd1-4...	SENT	2026-07-3...	2026-07-31...
fd7b3791-23af-4f44-a...	1376ca7e-99d3-...	SENT	2026-07-3...	2026-07-31...
b2e0b34a-7dbd-427a-...	8f587dd6-c415-4...	SENT	2026-07-2...	2026-07-28...
7565e61a-fd77-4d1f-...	f276fa4e-31c0-4...	SENT	2026-07-2...	2026-07-28...
e72dad6d-7c18-4c93-...	c2d68660-c7a3-4...	SENT	2026-07-2...	2026-07-28...
df3c17ca-3097-4170-...	88d54261-53e9-...	SENT	2026-07-2...	2026-07-28...
23f9170c-d115-4c63-...	93bb2fca-e71f-4...	SENT	2026-07-3...	2026-07-31...

> *“The design is a coherent system, not a collection of independent optimizations.”*

— dbnz/


Outbox Table
DynamoDB Streams
AWS
CloudTrail
Event Bridge
Rule
Processor
AWS Lambda
Signals Table
DynamoDB Streams
Alerter
AWS Lambda
Publisher
AWS Lambda
Amazon
GuardDuty
Event Bridge
Rule
Alerts Table
Notifier SQS
Responder
SQS
Notifier
AWS Lambda
Responder
AWS Lambda

[03]

Implementation

Serverless Framework

serverless.yml

opencdr-internal > serverless.yml

```yaml
service: opencdr
frameworkVersion: "3"

params:
  default:
    alarmEmail: ""
    alertEmail: ""  # email for security detection alerts; can match alarmEmail

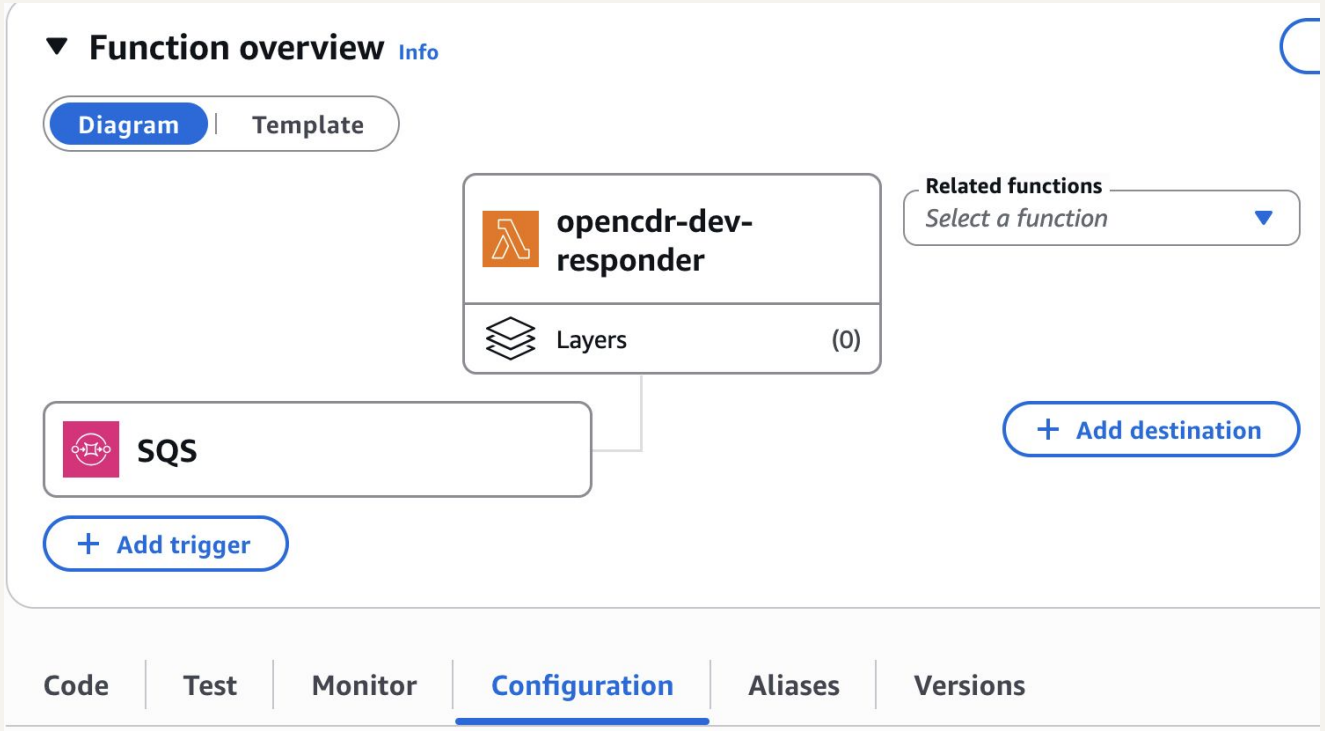
package:
  patterns:
    - src/openapi/swagger.json

provider:
  name: aws
  runtime: python3.12
  region: ${opt:region, 'us-east-1'}
  stage: ${opt:stage, 'dev'}
  logRetentionInDays: 90

  # AWS-native tracing (replaces the Phase 6 OTel/Sentry attempt, which hit
  # a real bug in a third-party instrumentor's API Gateway event handling --
  # AwsLambdaInstrumentor's attribute-extraction ran outside any exception
  # handling and threw on this repo's actual event shape, causing api.py to
  # 502 on every request). No app code, no third-party instrumentation
```

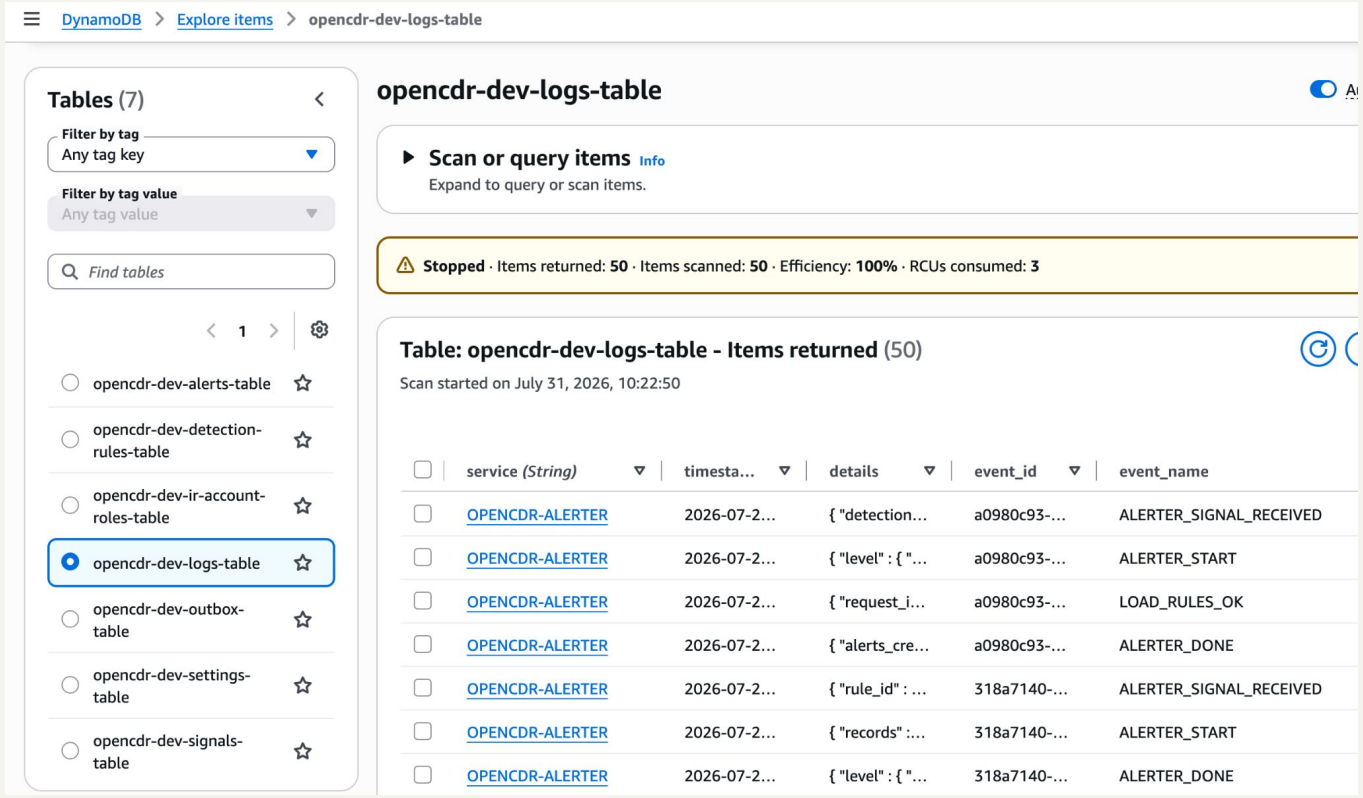
Infrastructure - Lambda

- Serverless function that **executes code only when triggered** by an event.
- No servers to manage—**AWS automatically provisions, scales, and patches the infrastructure**.
- Event-driven execution, **triggered by actions such as API requests**, file uploads, log events, or cloud configuration changes.
- **Ideal for automation**, making it a common building block for security monitoring, detections, and automated incident response..



Infrastructure - DynamoDB

- **Fully managed NoSQL database** designed for fast, low-latency access at virtually any scale.
- **Stores data as key-value pairs and documents,** rather than tables with complex relationships like traditional SQL databases.
- **Serverless and automatically scalable**, eliminating the need to manage database servers or capacity planning.
- Commonly used to store application state, configuration, session data, and security findings for cloud-native applications.



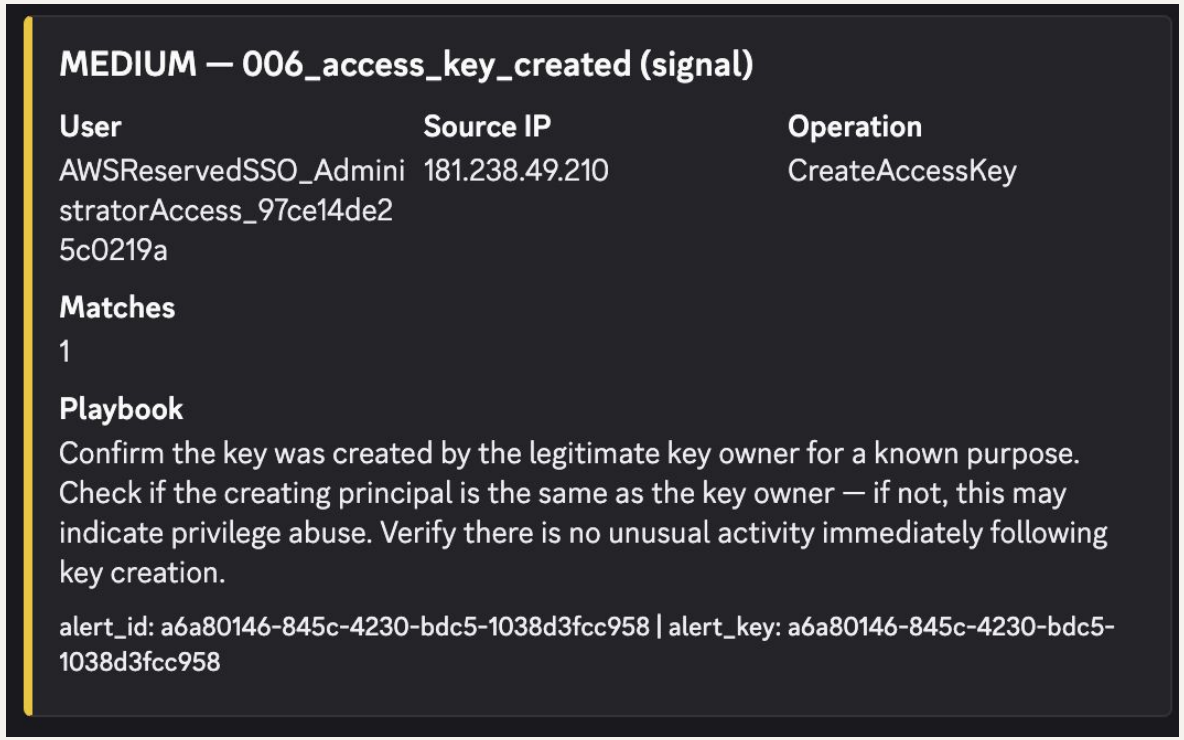
Signal and Correlation Rules

- **Signal rules match a single normalized event against a list of conditions** (field/op/value — equals, contains, regex, etc.); when all conditions pass, processor writes one signal. This is the atomic detection unit — e.g. "IAM access key created."
- Correlation rules don't look at raw events at all — **they group signals by a field** (group_by, e.g. actor.user_name)
- **Rules are data, not code** — both kinds live as rows in a DynamoDB table.
- **response_module is the bridge to automated response**


```
{
 "rule_kind": "signal",
 "rule_id": "006_access_key_created",
 "conditions": [
  {
   "field": "activity_name",
   "op": "equals",
   "value": "CreateAccessKey"
  },
  {
   "field": "api.service",
   "op": "equals",
   "value": "iam.amazonaws.com"
  }
 ],
 "created_by": "opencdr",
 "description": "New IAM access key created. Attackers create access keys for pe
 "enabled": true,
 "notify": true,
 "playbook": "Confirm the key was created by the legitimate key owner for a know
     the key owner - if not, this may indicate privilege abuse. Verify there is
 "response_module": "disable_access_key",
 "severity": "MEDIUM",
 "timestamp": "2026-04-03T16:13:28.302445+00:00",
```

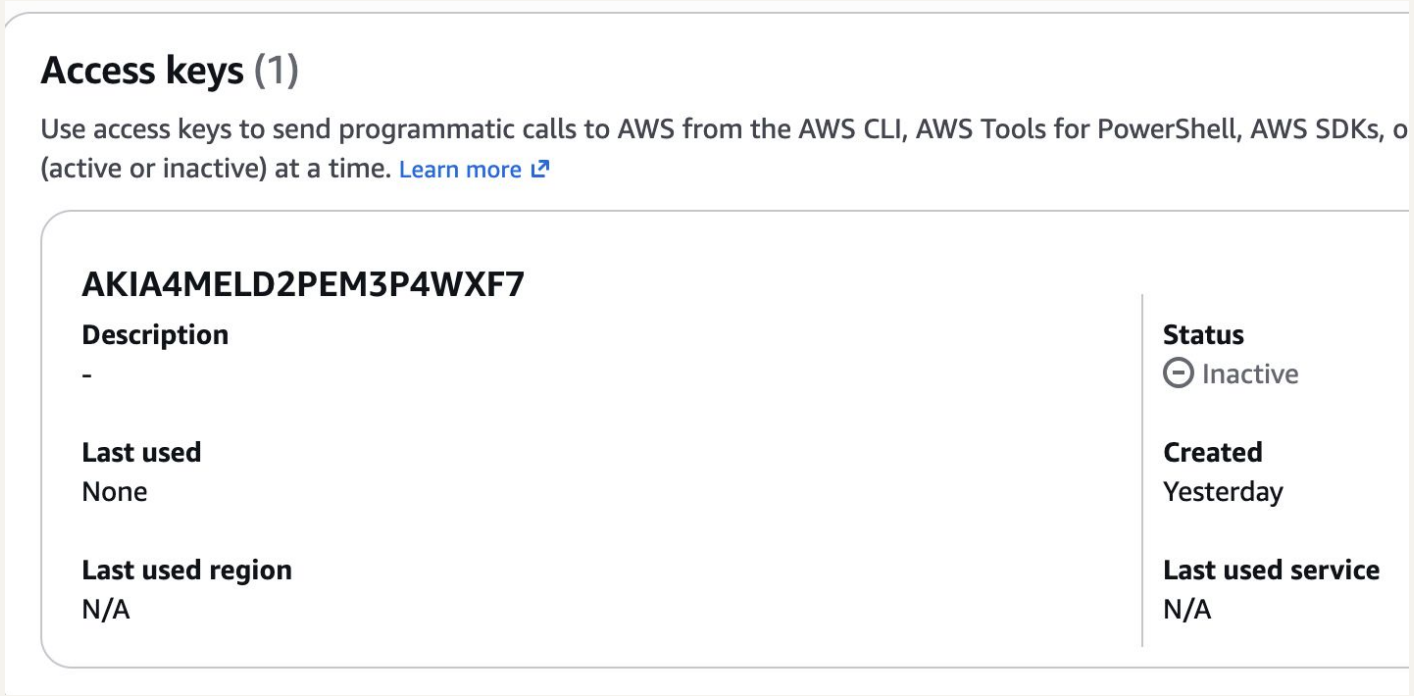
Notifications

- **Multi-channel by design** — one alert item can fan out to Slack, Discord, Email (via SNS), Security Hub (ASFF findings), Jira, and generic webhooks.
- All from the **same notifier Lambda** reading off the outbox-fed NotificationsQueue.
- **Severity drives both color and routing** — each channel builder maps severity to a visual signal (Slack attachment color, Discord embed color int),

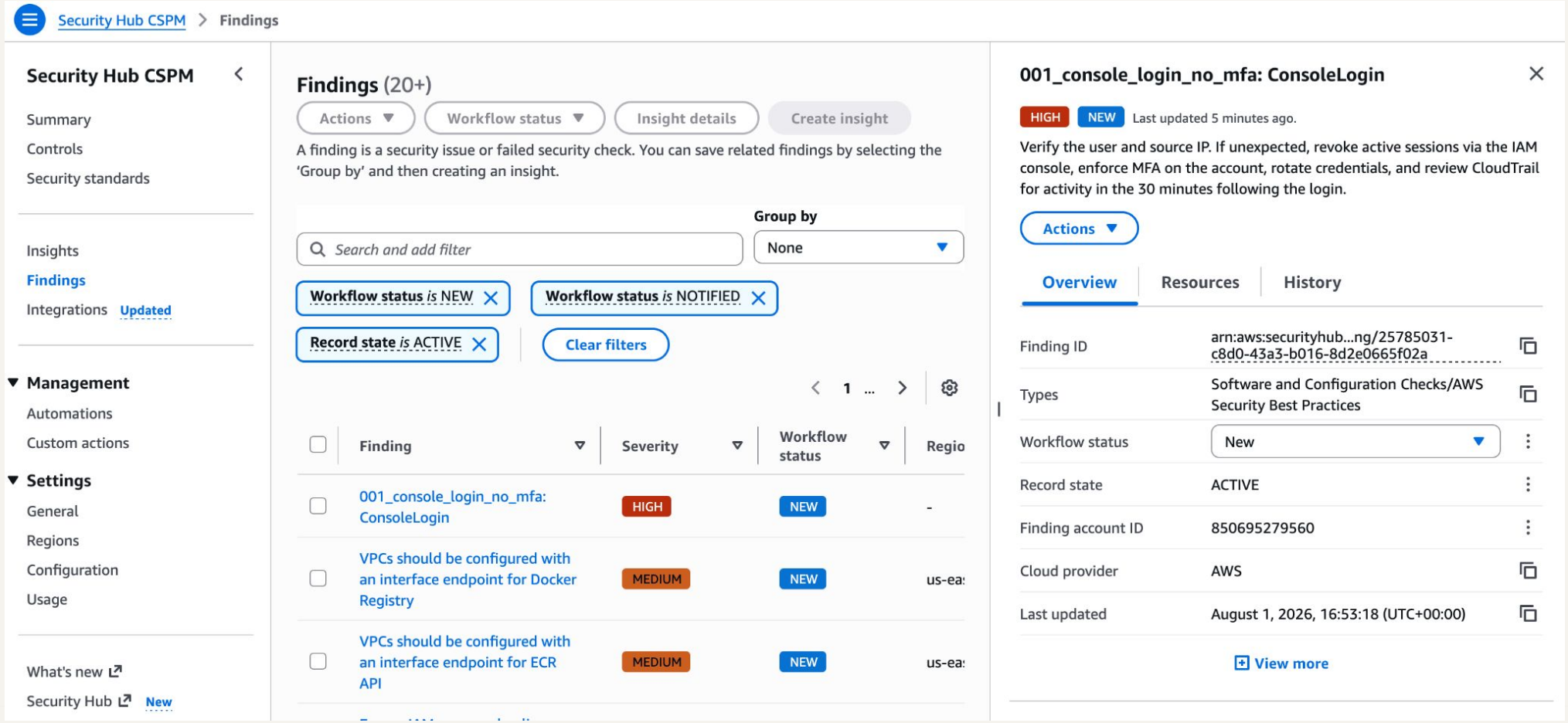


Automated Incident Response

- **Dispatch table, not a giant if/else** — a rule's response_module string (e.g. disable_access_key) is looked up in a handler dict; each handler knows how to pull the fields it needs.
- **The "how" is delegated to a separate library** the actual AWS mutation (revoke keys, disable a user, etc.) is executed by dredge.
- **Cross-account by design.**
- A circuit breaker sits in front of every action
- **Every outcome is logged as structured, auditable fact.**



Security Hub Integration



[/]

Demo [01]/

Real Time Threat Detection and Response

[/]

Demo [02]/

Deploying OpenCDR

> ”Do or do not. There is no try.”
> *Yoda - Star Wars*

— dbnz/

[/]

Questions?/

A Case for Event-Driven Cloud Detection and Response

01/08/2026 · Santiago Abastante

Linkedin: Santi Abastante - sabastante

Contact

Slides